

Slug: [/siem-nis2-dora-compliance](#)

Meta title: SIEM for NIS2 & DORA Compliance: A Guide

Meta description: Does your SIEM meet NIS2 and DORA requirements? See the 5 things a compliant platform must deliver, and where most tools fall short.

SIEM for NIS2 & DORA Compliance: What Your Platform Must Deliver

Quick answer: NIS2 and DORA are two EU rules. They tell companies to watch their systems for threats, keep clean records, and report problems fast. A SIEM helps you do all of this in one place. A SIEM (Security Information and Event Management) is software that collects logs from your systems and warns you when something looks wrong. It works best when it is built for these rules from the start.

Key Takeaways

- NIS2 covers 18 important sectors, like energy, health, and transport.
- DORA adds extra rules for banks, insurers, and other financial firms.
- Both rules want you to watch systems all the time, not just now and then.
- Both set tight deadlines to report problems. Manual work rarely meets them.
- Records must be tamper-proof. Many off-the-shelf tools do not lock records by default.
- Some companies build their own SIEM when a bought one cannot meet these rules.

What Is NIS2?

NIS2 is an EU rule that became active in October 2024. It aims to make key services safer from cyberattacks.

It covers 18 sectors. These include energy, transport, water, health, banking, and digital services. If your company runs one of these services, NIS2 likely applies to you.

Here is what NIS2 asks you to do:

- **Watch your systems all the time.** Checking logs once a week is not enough. You need near-real-time alerts.
- **Report serious problems fast.** Send a first alert within 24 hours. Send a full report within 72 hours.
- **Keep your logs.** National guidance points to at least 12 months.

- **Check your suppliers too.** Threats can come through third parties, so watch them as well.
- **Make leaders responsible.** Senior managers can be held personally liable if controls fail.

In short, NIS2 wants proof that your defenses actually work, not just that you bought them.

What Is DORA?

DORA is an EU rule that became active in January 2025. It focuses on the financial world.

DORA covers banks, insurers, payment firms, crypto firms, and the ICT partners that serve them. ICT means the tech systems and services a company depends on. DORA does not replace NIS2. It sits on top of it and adds more.

Here is what DORA adds:

- **Sort your incidents.** DORA uses a clear system to rank major problems by size and impact.
- **Report even faster.** Send a first alert within 4 hours for major incidents. Then a report at 72 hours, and a final one within one month.
- **Run attack tests.** Big firms must run TLPT at least every three years. TLPT (Threat-Led Penetration Testing) is a safe, planned attack test to check your defenses.
- **Track your partners.** Log which ICT partners you rely on and tie them to your risk records.
- **Prove resilience.** Show real evidence that your detection worked during tests.

DORA cares most about proof. You must show, with data, what happened and how you handled it.

What Does a SIEM Help With?

A SIEM pulls data from many systems into one place. Then it looks for threats and keeps records. This matches almost everything NIS2 and DORA ask for.

Here is how a SIEM supports both rules:

- **Central logging.** It collects logs from servers, apps, cloud tools, and more. This is your telemetry. Telemetry means the data your systems send about what they are doing.
- **Live threat detection.** It watches for odd patterns and raises alerts fast.
- **Incident context.** It links related events so you can judge how serious a problem is.
- **Faster response.** Many SIEMs pair with a **SOAR tool**. SOAR (Security Orchestration, Automation and Response) automates repeat steps to save time.

- **Audit-ready records.** It stores timestamped logs. An audit trail is a record of who did what and when.
- **Test evidence.** It can record attack tests and show which rules fired.

The bottom line: a SIEM turns messy logs into clear proof that your controls work.

What Must a Compliant SIEM Do?

Not every SIEM meets these rules out of the box. A compliant one needs 5 things.

1. Detection tied to the rules

Generic alerts are not enough. Your rules must match the incident types NIS2 and DORA define. Write down why each rule exists. Regulators may ask.

2. Automatic reporting

A 24-hour or 4-hour deadline leaves no time for manual work. Your SIEM should automate:

- Alert sorting by severity
- Handoff to your response team
- Draft reports in the right format
- A timestamped record of every step

This usually runs through [a SOAR playbook](#) built into the SIEM.

3. Tamper-proof records

Logs that anyone can delete will fail both rules. You need:

- Write-once storage (called WORM, meaning logs cannot be changed once saved)
- Checks that prove logs were not altered
- Access logs for every analyst action
- Retention rules that admins cannot switch off

This is one of the most common gaps in bought SIEMs.

4. EU data storage

Logs for EU operations often must stay in the EU. This is called data residency. Data residency means keeping data inside a set region. For firms across many countries, this may mean routing each unit's data on its own. For MSSPs serving multiple EU clients, [see how multi-tenant SIEM architecture handles](#) per-tenant data routing.

5. Resilience testing

DORA wants proof that detection worked during tests. Your SIEM should:

- Record attack tests as events
- Confirm the right rules fired
- Produce gap reports after each test
- Track fixes over time

NIS2 vs DORA: The Key Differences

The table below shows the key differences side by side.

Requirement	NIS2	DORA
Who it covers	18 key sectors	Financial firms + ICT partners
Watch systems always	Yes	Yes
First alert	Within 24 hours	Within 4 hours (major)
Full report	Within 72 hours	Within 1 month
Keep logs	About 12 months	Per your risk framework
Attack testing	Based on risk	TLPT every 3 years
Watch suppliers	Yes	Yes + partner register
Leaders liable	Yes	Yes

EU data storage	Often needed	Often needed
-----------------	--------------	--------------

For financial firms in the EU, both rules apply at once. When they overlap, the stricter one wins.

Compliant vs Non-Compliant SIEM

This table shows the clear line between the two.

Capability	Compliant SIEM	Non-Compliant SIEM
Detection tied to NIS2/DORA	Yes	Generic only
Automatic reporting	Yes, with records	Manual, no record
Tamper-proof storage	WORM + checks	Can be deleted
EU data storage	Per unit, at intake	Not controlled
Incident sorting	Clear system	Loose and messy
Test evidence	Built in	Not supported
Retention lock	Cannot be bypassed	Can be bypassed
Supplier monitoring	Tied to risk records	Perimeter only

Why Many Teams Hit Limits With Bought SIEMs

Most commercial SIEMs were built to catch threats. They were not built for strict compliance at scale. Three gaps show up again and again.

- **Reporting gaps.** Most tools send alerts. Few send ready-to-file reports with full records. Teams fill the gap by hand, and that fails under pressure.
- **Cost and storage limits.** Retention is often tied to your license tier. Costs climb fast at compliance-grade volumes. For a closer look at how ingestion pricing affects your budget, see our [SIEM cost](#) analysis. EU storage may also need a separate setup you did not plan for.
- **Weak record locks.** Tools that allow log deletion, even with access controls, often struggle to prove records are tamper-proof.

Knowing these gaps early helps you avoid a tool that cannot meet the rules.

When Does a Custom-Built SIEM Make Sense?

For many firms, compliance is the trigger to build their own platform. But the value goes further.

A purpose-built SIEM gives you tuned detection, reporting made for the rules, and full ownership. You are not stuck working around a product that was never built for this. If you are replacing an existing platform rather than starting fresh, our [SIEM migration guide](#) covers how to switch without a coverage gap.

The math changes once you add up license costs at large log volumes, the work of bolting compliance onto a bought tool, and the risk of gaps a regulator could flag. Building rather than patching often wins over time, both in cost and control. MSSPs looking to offer this as a managed service can also [see how our MSSP partnership model works](#).

Custom is not for everyone. Small teams with simple needs may do fine with a well-tuned commercial tool. But once your log volume, sectors, or deadlines outgrow what a bought platform can handle, an [engineering-built SIEM and SOAR platform](#) becomes the practical choice.

Check Your Platform Before a Regulator Does

Most compliance gaps show up during audits and real incidents, not during vendor demos. That is the worst time to find them.

A structured review is the fastest way to see where you stand. It maps your platform against NIS2 and DORA, finds your biggest gaps, and gives you a clear fix plan.

[Book an Architecture Audit →]

Frequently Asked Questions

Does NIS2 require a SIEM?

No exact tool is required. But NIS2 wants always-on monitoring, threat detection, and clear reporting at scale. In practice, that needs a SIEM or a similar platform.

What is the NIS2 reporting deadline?

Send a first alert within 24 hours of spotting a serious incident. Send a full report within 72 hours. Some countries add extra steps, so check your local version of the rule.

How is DORA's timeline different from NIS2?

DORA is tighter. It wants a first alert within 4 hours for major incidents, a report at 72 hours, and a final report within one month. That 4-hour window makes automation very important.

What does "tamper-proof audit trail" mean?

It means no one can change or delete the logs, not even admins. WORM storage and integrity checks are the standard way to do this. Access to those logs should also be logged.

Does DORA apply to non-financial companies?

It can. If your company provides critical ICT services to financial firms, you may fall in scope as a third-party provider. Check your obligations to be sure.

Can a bought SIEM meet NIS2 and DORA?

Some can be set up to meet many rules. Common gaps are tamper-proof storage, EU data storage, and automatic reporting. Always check against the real rule text, not vendor claims.

How long must logs be kept?

NIS2 guidance points to at least 12 months, though this varies by country and sector. DORA ties retention to your ICT risk framework and any recordkeeping rules that apply.

What is telemetry?

Telemetry is the data your systems send about what they are doing. Logs, events, and metrics are all telemetry. A SIEM collects this data to spot threats and prove what happened.